

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Clínica Privada - Evaluación de Riesgos de Seguridad

1. Resumen ejecutivo

Se llevó a cabo una evaluación inicial de riesgos sobre una clínica privada que cuenta con 120 empleados, atiende aproximadamente 800 pacientes por día y utiliza sistemas informáticos para gestionar historias clínicas digitales, turnos, información de obras sociales y procesos administrativos.

El análisis identificó como principales áreas de exposición la protección de las credenciales del personal, la propagación de software malicioso, la disponibilidad de la infraestructura tecnológica, la integridad de los datos médicos y el manejo de información sensible.

Los resultados muestran una concentración de riesgos altos y críticos que podrían comprometer tanto la continuidad de los servicios asistenciales como la confidencialidad e integridad de la información de los pacientes. En consecuencia, se considera prioritario fortalecer los controles de identidad, la protección de los equipos y la disponibilidad de la infraestructura crítica.

2. Top 5 de riesgos

Riesgo	Probabilidad	Impacto	Valor	Nivel
Compromiso de credenciales del personal médico	4	5	20	Crítico
Propagación de malware desde equipos administrativos	4	5	20	Crítico
Caída de infraestructura que soporta la atención de pacientes	3	5	15	Alto
Modificación accidental de datos médicos por permisos excesivos	3	5	15	Alto
Envío accidental de información sensible a terceros no autorizados	3	4	12	Alto

Los riesgos ubicados en los primeros lugares requieren atención prioritaria debido a que pueden afectar información médica sensible y provocar interrupciones relevantes en los servicios utilizados durante la atención de pacientes.

3. Estado de los planes de acción

Se definieron tres planes de mitigación prioritarios:

- Programa de protección de identidades clínicas
 - Riesgo asociado: compromiso de credenciales del personal médico.
 - Responsable: Valentina Ríos.
 - Vencimiento: 20/10/2026.

- Presupuesto estimado: USD 3.200.
 - Estado inicial: No iniciado (0%).
2. Fortalecimiento de endpoints y segmentación de red
- Riesgo asociado: propagación de malware desde equipos administrativos.
 - Responsable: Responsable de Seguridad.
 - Vencimiento: 05/11/2026.
 - Presupuesto estimado: USD 7.500.
 - Estado inicial: No iniciado (0%).
3. PPlan de alta disponibilidad para servicios asistenciales
- Riesgo asociado: caída de infraestructura que soporta la atención de pacientes.
 - Responsable: Valentina Ríos.
 - Vencimiento: 05/12/2026.
 - Presupuesto estimado: USD 6.500.
 - Estado inicial: No iniciado (0%).

4. Recomendaciones prioritarias

Se recomienda implementar autenticación multifactor para los accesos a sistemas que procesan información clínica y revisar periódicamente los privilegios asignados a cada perfil. Estas medidas deberían completarse con capacitación frente a phishing y mecanismos de monitoreo que permitan detectar accesos anómalos.

También resulta prioritario fortalecer la protección de las estaciones de trabajo mediante tecnologías de detección y respuesta, segmentar la red para limitar la propagación de incidentes y mantener copias de seguridad aisladas y verificadas mediante pruebas periódicas de restauración.

Para los servicios vinculados directamente con la atención de pacientes se recomienda incorporar redundancia, monitoreo de disponibilidad y procedimientos de contingencia que permitan continuar las operaciones esenciales ante una falla tecnológica.

Por último, los centros de datos y demás infraestructura tecnológica crítica no deberían ubicarse junto a cocinas ni debajo de piletas, debido a la exposición innecesaria a riesgos de incendio e inundación respectivamente.

La aplicación progresiva de estas medidas permitirá disminuir la exposición de la organización, fortalecer la protección de la información clínica y mejorar la capacidad de respuesta y recuperación frente a incidentes.